

Part 3: Incident Response Fundamentals

Incident Response (IR) is a structured approach to handling security incidents. A well-defined IR process minimizes damage, reduces recovery time and costs, and prevents future incidents. The SANS Institute defines six phases of the Incident Response Lifecycle.

3.1 The Incident Response Lifecycle (SANS Framework)

Phase	Goal	Key Activities	Tools / Resources
1. Preparation	Build capabilities before an incident occurs.	Develop IR policy and playbooks. Train the SOC team. Deploy monitoring tools (SIEM, EDR). Establish communication trees. Run tabletop exercises to test the plan.	Wazuh, Velociraptor, Slack (comms), SANS IR templates, Tabletop exercise guides
2. Identification / Detection	Determine whether an incident has actually occurred.	Monitor SIEM alerts and IDS/IPS logs. Analyze endpoint alerts (EDR). Triage alerts by severity (P1–P4). Validate true positives vs. false positives. Document initial findings.	Elastic SIEM, Suricata, Wazuh alerts, CrowdSec, Sigma rules
3. Containment	Limit the scope and impact of the incident.	Short-term: Isolate infected system from network. Block attacker's IP via firewall. Disable compromised user	CrowdSec, iptables, VirtualBox network isolation, AD account management



Phase	Goal	Key Activities	Tools / Resources
		accounts. Long-term: Apply patches, change passwords, improve controls.	
4. Eradication	Remove the threat completely from the environment.	Delete malware files and backdoors. Remove persistence mechanisms (startup entries, cron jobs, scheduled tasks). Patch the exploited vulnerability. Scan for IOCs across all systems.	Malwarebytes, Velociraptor artifact collection, OpenVAS, manual forensics
5. Recovery	Restore systems to normal operations safely.	Restore systems from verified clean backups. Monitor restored systems closely for 24–72 hours. Verify all services are operational. Confirm attacker has no remaining access.	Backup solutions, Wazuh monitoring, network traffic analysis
6. Lessons Learned	Improve future response capabilities.	Conduct post-incident review within 2 weeks. Document what happened, timeline, root cause, what worked, what failed. Update IR playbooks. Report to management. Submit IOCs to threat intel feeds.	Google Docs report, MITRE ATT&CK mapping, CISA reporting portal

3.2 Key IR Concepts

SOC Workflow and Incident Prioritization

Priority	Level	Description	Response Time	Example
P1	Critical	Active compromise with data exfiltration or ransomware in progress.	Immediate (< 15 min)	Ransomware encrypting files on production server.
P2	High	Confirmed intrusion but limited impact. Attacker has foothold but no lateral movement yet.	< 1 hour	Malicious PowerShell execution detected on workstation.
P3	Medium	Suspicious activity requiring investigation. Possible breach indicator.	< 4 hours	Multiple failed login attempts from foreign IP.
P4	Low	Informational event. Policy violation or low-risk finding.	< 24 hours	User visited blocked website. Antivirus detected PUA.

IR Playbook — Phishing Incident

- Step 1 — Detection: SIEM or user reports suspicious email. SOC analyst receives alert.
- Step 2 — Triage: Analyst reviews email headers, links, attachments. Checks sender reputation (VirusTotal, URLScan).
- Step 3 — Containment: Block sender domain at email gateway. Quarantine email across all mailboxes. Isolate affected user's machine if attachment was opened.
- Step 4 — Investigation: Check if user clicked link or opened attachment. Review process creation logs (Event ID 4688). Look for malicious child processes.
- Step 5 — Eradication: Remove malware. Reset user credentials. Block C2 domains/IPs in firewall.
- Step 6 — Recovery: Restore files if needed. Re-enable user account. Confirm system is clean.
- Step 7 — Documentation: Write incident report. Update email filter rules. Brief user on phishing awareness.